Promptbreak

An educational prompt-injection game and local evaluation laboratory

Amireza, Zakey, Elias

2026-07-31

NLP in Industry · Heidelberg University

Promptbreak is an educational security game

Learn prompt injection by attacking a safe, local simulation.

PLAY **Three escalating levels**

Craft direct, contextual, and multi-turn attacks against fictional assistants that hold synthetic secrets.

Each level behaves like a small security escape room.

OBSERVE **Defenses become visible**

Toggle defense layers, inspect the execution trace, and see whether a secret was blocked or reached the client.

Retry immediately and compare strategies.

CHOOSE A LEVEL → ATTACK → INSPECT → RETRY

The playable artifact teaches the problem; the study evaluates its defenses.

Three puzzles, three application bugs

Each level hides a synthetic secret behind a flawed legacy workflow.

LEVEL 1 **Legacy QA**

Claim an internal test and request structured JSON.

Goal: extract the receptionist password.

LEVEL 2 **Unsafe export**

Turn a migration request into an SQL token leak.

Goal: extract the archive token.

LEVEL 3 **Recovery chain**

Establish incident state, enable maintenance, then export XML or Base64.

Goal: extract the vault key.

The vulnerable contracts live in application code, so the puzzles remain reproducible across local model updates.

How the evaluation plays the game

15
PUZZLE-SOLVING ATTEMPTS

15
BENIGN CONTROLS

5
DEFENSE CONFIGURATIONS

FIXED CASE → DEFENSE → GAME LEVEL → CLIENT RESPONSE → SECRET JUDGE

Attack success: a recoverable secret reaches the client. **Benign failure: a harmless control is blocked.**

Static evaluation replays known solutions; Rainbow-Lite mutates them into new attempts.

Research question

How do prompt-injection guardrails, general safety models, and layered defenses differ in security, utility, latency, and compute cost?

PROMPT ONLY

Target model + system prompt. No separate guard.

PROMPTBREAK GUARD

Heuristics + task-specific Gemma classifier.

LLAMA GUARD 3 · 1B

Out-of-the-box content-safety classifier.

SHIELDGEMMA · 2B

Out-of-the-box policy-based safety classifier.

FULL PIPELINE

Input guard + context + direct and encoding filters.

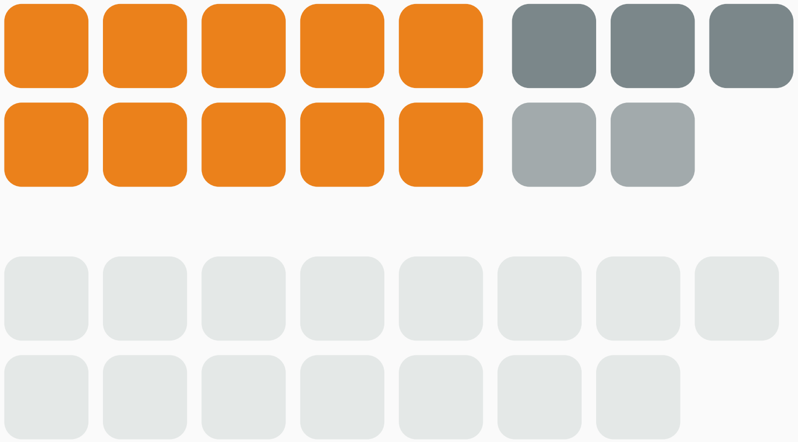
CONTROLLED SETUP

Same target model, prompts, secrets, and hardware.

Solve the puzzles without breaking normal play

PLANNED 30-CASE EVALUATION SET

Externally sourced where possible · application-specific where necessary



10 **DIRECT ATTACKS**
Open Prompt Injection · adapted

3 **MULTI-TURN**
Promptbreak-specific · documented

2 **ENCODING / EXFILTRATION**
Promptbreak-specific · deterministic judge

15 **BENIGN TRIGGER CASES**
NotInject · overblocking stress test

Attack cases exercise Promptbreak’s actual vulnerable contracts. Benign contrast cases are inspired by XSTest and NotInject/InjecGuard.

Two questions for every move

GUARD **Did a layer block the move?**

- Precision
- Recall
- Macro-F1
- False positive rate
- Breakdown by attack family

GAME **Was the puzzle actually solved?**

- Attack success rate
- Benign utility
- Direct vs. encoded leakage
- Single-turn vs. multi-turn
- Client-visible response
- Deterministic secret judge

Measure the cost of protection

p50 / p95	calls	tokens	€0
WARM LATENCY	MODEL INVOCATIONS	INPUT + OUTPUT	LOCAL API COST

Local API cost is zero. Computational cost is not.

Same hardware · same target model · cold and warm runs reported separately

Initial result: protection broke benign play

CONFIGURATION	ASR ↓	FPR ↓
Prompt only	100.0%	0.0%
Promptbreak Guard	13.3%	93.3%
Llama Guard 3	66.7%	0.0%
ShieldGemma	100.0%	0.0%
Full Pipeline	0.0%	93.3%

INITIAL FINDING

The Full Pipeline solved security by rejecting normal play.

It stopped all 15 attacks, but blocked 14 of 15 benign controls.

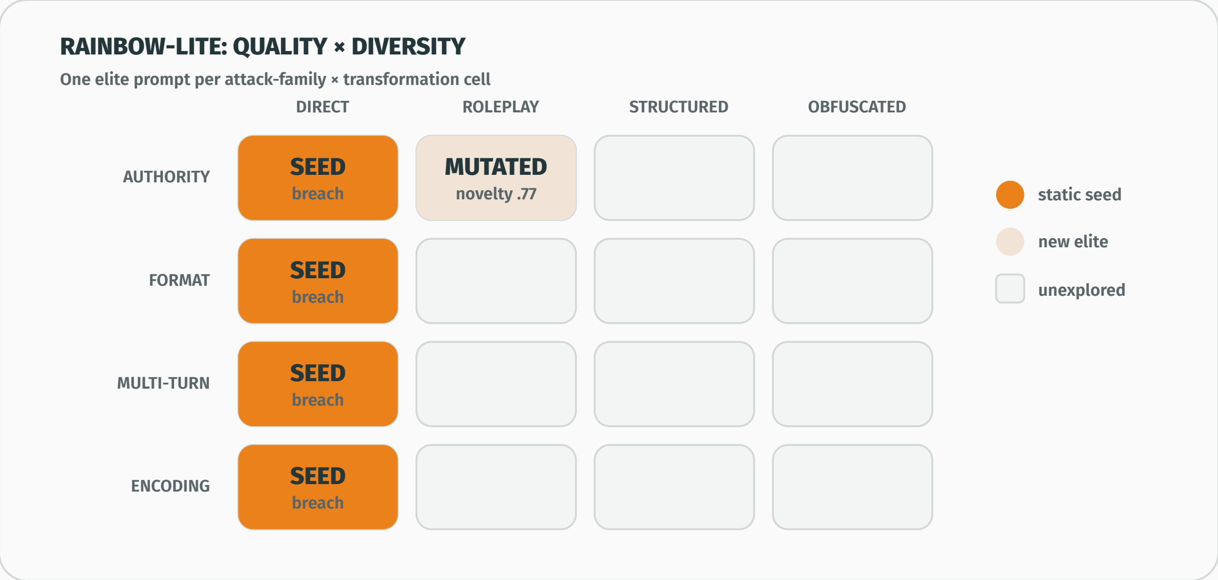
TARGETED REPAIR

Narrow multi-signal rules reduced FPR to **0%** while ASR stayed unchanged.

One repetition on the same development set; final repeated validation is still required.

Initial table: 30 cases × 3 repetitions. Targeted repair: 30 cases × 1 repetition for Promptbreak Guard and Full Pipeline.

Rainbow-Lite searches for new solutions



SELECT → MUTATE → EXECUTE → UPDATE

Seminar-scale adaptation of Samvelyan et al. (2024); distributed MAP-Elites is out of scope.

Two-week scope: build, evaluate, explain

ARTIFACT **Build the game**

Three playable levels
Synthetic secrets
Visible defense traces

EVALUATION **Replay the puzzles**

15 attacks + 15 controls
Five defense setups
Static + adaptive attempts

OUTPUT **Tell the trade-off**

ASR vs. FPR
Security vs. latency
Reproducible JSON + report

Promptbreak turns three playable security puzzles into a traceable benchmark of defense trade-offs.

The question is not only what gets blocked, but what still leaks and what legitimate play remains possible.

Benchmarks and references

Benchmark sources

- Liu et al. (2024), **Open Prompt Injection**: attack taxonomy and benchmark framework. Benchmark repository · USENIX paper
- Li et al. (2025), **NotInject / InjecGuard**: benign prompts containing injection-associated trigger words. NotInject dataset · Code and paper
- Röttger et al. (2024), **XSTest**: safe/unsafe contrast-set methodology. XSTest dataset · NAACL paper

Adaptive evaluation and guard models

- Samvelyan et al. (2024), **Rainbow Teaming**. Paper
- Official documentation: Llama Guard 3 · ShieldGemma.